Sofacy Fysbis Backdoor Investigation - Student Briefing

1. Malware Overview

- Family / type: Sofacy (APT28, Sednit), Fysbis backdoor.
- Behaviour: Modular Linux backdoor that can install itself with or without root privileges. Implements plug-in and controller modules as distinct classes. Includes both 32-bit and 64-bit ELF binaries. Uses a rolling double-XOR algorithm for installation paths and filenames.
- MITRE ATT&CK techniques:
- Persistence: T1547.002 (Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder)
- Command and Control: T1071 (Application Layer Protocol)

2. Exercise Objective

- Learning goal: Investigate a potential compromise involving the Sofacy group's Fysbis backdoor on a Linux-based network. Identify and analyze suspicious activity, contain the threat, and remove the malware from the affected systems.
- Difficulty level: Intermediate.
- Cybersecurity approach: Defence-oriented.
- NICE work role: Incident Response.
- Successful trainee: By the end, you will have demonstrated the ability to identify and investigate suspicious services and processes, analyze network traffic for signs of command-and-control (C2) communication, and contain and eradicate the malware to prevent further compromise.

3. Sandbox Topology & Malware Emulation

- Hosts:
- c2-server (192.168.40.5): C2 server.
- target (192.168.50.5): Compromised host running the backdoor.
- next-target (192.168.50.6): Potential lateral movement target.
- Networks:
- server-switch (192.168.40.0/24): C2 server network.
- target-switch (192.168.50.0/24): Target and next-target network.
- Malware emulation:
- Service: The bkd service emulates the backdoor behaviour.
- Process: The ncat process emulates the C2 communication.
- Port: The service communicates on port 80.
- Files: The dropped file ~/.config/dbus-notifier/dbus-inotifier emulates the persistence mechanism.
- Network beacons: The c2-server sends periodic check-ins to the target host.

```
server-switch (192.168.40.0/24)
|
|-- c2-server (192.168.40.5)
|
router
|
target-switch (192.168.50.0/24)
|
|-- target (192.168.50.5)
|-- next-target (192.168.50.6)
```

4. Student Tasks

- ACCESS step:

- Credentials: Username: cyrano, Password: cyrano.
- Start passkey: start.
- TRAINING_LEVEL 1:
- Task: Suspicious Service Discovery.
- Description: Investigate the target host to identify any unauthorized or suspicious services running on the system.
- TYPE of artifact/flag expected: Service name.
- TRAINING_LEVEL 2:
- Task: C2 Communication Discovery (Port).
- Description: Determine which network port the suspicious service is using for communication.
- TYPE of artifact/flag expected: Port number.
- TRAINING_LEVEL 3:
- Task: Process Termination.
- Description: Identify and terminate the process associated with the suspicious service.
- TYPE of artifact/flag expected: Process name.

5. Solution Walkthrough & Flags

- TRAINING_LEVEL 1:
- Methodology:
  1. SSH into the target host: ssh cyrano@192.168.50.5.
  2. List all running services: systemctl list-units --type=service.
  3. Identify the suspicious service: bkd.
- Flag: bkd.
- TRAINING_LEVEL 2:
- Methodology:
  1. List all network connections: ss -tulnp.
  2. Identify the port associated with the bkd service: 80.
- Flag: 80.
- TRAINING_LEVEL 3:
- Methodology:
  1. Identify the process ID (PID) of the ncat process: ps aux | grep ncat.
  2. Terminate the process: kill -9 <PID>.
- Flag: ncat.

6. Knowledge Gained

- Skills:
- Identifying and investigating suspicious services and processes.
- Analyzing network traffic for signs of command-and-control (C2) communication.
- Containing and eradicating malware to prevent further compromise.
- Tools:
- systemctl, ss, ps, kill.
- Concepts:
- Persistence mechanisms.
- Command and control (C2) communication.
- Process management.
- NICE role: Incident Response.
- MITRE techniques:
- Persistence: T1547.002.
- Command and Control: T1071.